COMPTIA SECURITY+ SY0-701 | DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.1 · Security Standards

Mestre CyberSec · **Aula 5.1 — Security Standards** (5:36) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Standards = MANDATÓRIO e específico (password standards, access control standards); Guidelines = SUGERIDO/best practice (não obrigatório); Procedures = passo-a-passo de uma tarefa.

💡 Highlights que a prova CompTIA cobra

- Standard: MANDATÓRIO; Guideline: SUGESTÃO; Procedure: passo-a-passo

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'mandatory document defining how to implement policy'=standard

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.1 — Security Standards)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Padrão / Norma de Segurança

Documento obrigatório e específico da organização que define COMO uma política deve ser implementada, como padrões de senha ou de controle de acesso. O cumprimento é exigido, não opcional.

⚠ ***Armadilha CompTIA:*** *Gatilho: 'mandatory document defining how to implement policy' = STANDARD. É específico e obrigatório — não confunda com Guideline (sugestão, opcional) nem com Procedure (passo a passo de UMA tarefa).*

• Diretriz

Guia recomendado e não obrigatório (melhor prática) que oferece flexibilidade e sugestões sobre como cumprir políticas e padrões; não é exigido segui-la exatamente.

⚠ ***Armadilha CompTIA:*** *Gatilho: 'suggestion / recommendation / best practice' = GUIDELINE. Se a questão disser 'mandatory / required', não é guideline — vira Standard. Diretriz orienta, não obriga.*

• Procedimento (SOP)

Conjunto detalhado de instruções passo a passo (Procedimento Operacional Padrão) que descreve exatamente como executar UMA tarefa específica, como restaurar um backup ou redefinir uma senha.

⚠ ***Armadilha CompTIA:*** *Gatilho: 'step-by-step how-to de uma tarefa específica' = PROCEDURE. Standard define requisitos (o QUÊ); Procedure descreve os passos (o COMO). SOP = Standard Operating Procedure.*

• Política

Declaração de alto nível e obrigatória de intenção da alta gestão que define O QUE a organização quer alcançar em termos amplos; é implementada por meio de padrões e procedimentos.

⚠ ***Armadilha CompTIA:*** *Hierarquia clássica de prova: POLICY = O QUÊ (ampla, obrigatória) → STANDARD = requisitos específicos para implementar a política → PROCEDURE = passos práticos; GUIDELINE = sugestão opcional em qualquer nível.*

• Governança

Estrutura geral de políticas, padrões, diretrizes, procedimentos e mecanismos de conformidade que direciona e controla como a estratégia e o comportamento de segurança são gerenciados na organização.

⚠ ***Armadilha CompTIA:*** *Objetivo SY0-701 5.1 = elementos de governança. Perguntas sobre 'quem decide e como as regras se aplicam' apontam para governance: policies + standards + procedures + guidelines + compliance interno e externo.*

• Conformidade Regulatória Externa

Obrigação de obedecer a leis e regulamentos impostos por entidades ou governos externos (ex.: GDPR, HIPAA, PCI DSS); violações podem gerar multas e penalidades legais.

⚠️ ***Armadilha CompTIA:*** *Gatilho: regra imposta por governo/autoridade externa = EXTERNAL regulatory compliance. Erro comum: achar que compliance é só interno — o regulador manda, não a empresa.*

• Conformidade Interna

Adesão às regras, políticas e padrões criados e aplicados pela própria organização, geralmente verificados por auditorias internas (ex.: exigência de treinamento anual de segurança).

⚠️ ***Armadilha CompTIA:*** *Distinção chave: requisito da PRÓPRIA empresa = INTERNAL compliance; exigido por LEI/REGULADOR ou contrato com terceiro = EXTERNAL. O auditor interno verifica internos; o governo/regulador verifica externos.*

• Linha-base / Configuração Mínima

Configuração ou nível mínimo obrigatório de segurança que todos os sistemas devem atender antes de entrar em produção; padrões costumam definir como essas linhas-base são implementadas.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'minimum level that ALL systems must meet' = BASELINE (mínimo obrigatório de partida). Standard = regra escrita de como implementar; baseline = a configuração mínima que decorre dessas regras.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

A política aprovada pelo conselho de uma empresa determina que todos os sistemas corporativos devem ser protegidos por autenticação forte. O CISO agora precisa de um documento complementar que defina explicitamente os parâmetros obrigatórios de senha para toda a organização — mínimo de 12 caracteres, letras maiúsculas e minúsculas, números, símbolos e proibição de reutilizar as cinco últimas senhas. A conformidade com esse documento será auditada, e exceções exigem aprovação formal. Qual tipo de documento atende a essa necessidade?

A) Uma diretriz interna, porque as configurações de senha variam entre sistemas operacionais

B) Um padrão de segurança, porque contém requisitos específicos e obrigatórios que dão suporte à política

C) Uma linha de base, porque registra a configuração atual de cada sistema

D) Um procedimento, porque orienta o usuário sobre como alterar a senha

QUESTÃO 2 · CENÁRIO DE EXAME

A equipe de segurança deseja documentar práticas recomendadas de proteção para smartphones corporativos, como habilitar criptografia de disco completo, desativar lojas de aplicativos de terceiros e exigir desbloqueio biométrico. A gestão deixa propositalmente as decisões de imposição flexíveis, porque diferentes departamentos têm necessidades operacionais distintas. Qual tipo de documento a equipe deve produzir?

A) Um padrão de imposição obrigatória aprovado pelo CISO

B) Um procedimento passo a passo de registro no MDM

C) Uma diretriz de boas práticas

D) Uma política de uso aceitável emitida pelo conselho

QUESTÃO 3 · CENÁRIO DE EXAME

Depois que um ransomware entrou na rede por meio de um e-mail de phishing, o líder de resposta a incidentes descobriu que cada analista do SOC conteve o surto de uma maneira diferente — alguns isolaram hosts, outros desligaram as máquinas e alguns coletaram imagens forenses na ordem errada. O líder quer que todos os analistas executem a contenção exatamente da mesma forma de agora em diante. Qual tipo de documento deve ser criado?

A) Um procedimento de contenção com ações ordenadas, passo a passo

B) Uma política de gestão declarando que o ransomware deve ser prevenido

C) Um padrão definindo a criptografia exigida para backups

D) Uma diretriz sugerindo que os analistas revisem incidentes anteriores

QUESTÃO 4 · CENÁRIO DE EXAME

Durante uma reunião estratégica, o conselho de diretores de uma organização aprova um documento que declara: 'A confidencialidade, integridade e disponibilidade de todos os dados de clientes devem ser protegidas onde quer que sejam criados, armazenados ou transmitidos, em nível compatível com o risco do negócio.' O conselho atribui à alta gestão a responsabilidade pela implementação, mas não fornece detalhes técnicos. Que tipo de documento o conselho aprovou?

A) Uma linha de base de configuração

B) Um padrão de implementação

C) Um procedimento técnico detalhado

D) Uma política organizacional de alto nível

QUESTÃO 5 · CENÁRIO DE EXAME

A equipe de infraestrutura em nuvem quer que cada nova instância de Windows Server seja implantada com as mesmas proteções mínimas: serviços desnecessários desativados, registro de auditoria habilitado, BitLocker obrigatório, contas de administrador local renomeadas e TLS 1.2 como protocolo mínimo permitido. Sistemas de produção abaixo dessas configurações não podem entrar em operação. O que a equipe deve documentar formalmente para definir esse limite de aceitação?

A) Um procedimento de correção para servidores individuais

B) Uma diretriz de segurança permitindo ajustes por equipe

C) Uma linha de base de configuração mínima para a plataforma

D) Uma regulamentação externa exigindo atestações de nuvem

QUESTÃO 6 · CENÁRIO DE EXAME

Uma empresa de serviços para comerciantes aceita cartões de pagamento para vendas online. Um órgão externo do setor publica um conjunto detalhado de requisitos de segurança cobrindo segmentação de rede, criptografia de dados de titulares de cartão e registro de acessos, e impõe multas — e possível perda dos privilégios de processamento de cartões — a empresas que falharem na avaliação. O gerente de segurança deve mapear cada um desses requisitos para controles internos e comprovar conformidade anualmente. Que tipo de obrigação de conformidade é essa?

A) Uma obrigação de conformidade interna baseada nos padrões da própria empresa

B) Uma obrigação de conformidade regulatória imposta externamente

C) Um requisito de linha de base definido pela equipe de segurança

D) Uma diretriz que a empresa pode adotar por vontade própria

QUESTÃO 7 · CENÁRIO DE EXAME

Antes de uma avaliação futura, o responsável por conformidade reúne evidências de que a organização está atendendo aos seus próprios padrões de controle de acesso, padrão de senhas e requisitos de gerenciamento de mudanças — documentos criados pelo departamento de segurança e aprovados pela gestão. Nenhum órgão governamental ou entidade do setor impõe essas regras específicas à organização. Como o responsável deve classificar esse trabalho de conformidade?

A) Conformidade interna com requisitos organizacionais autoimpostos

B) Conformidade regulatória externa com uma exigência governamental

C) Conformidade contratual com um adendo de segurança de um cliente

D) Alinhamento de melhor esforço com diretrizes de fornecedores

QUESTÃO 8 · CENÁRIO DE EXAME

Durante a integração à equipe de segurança, um analista júnior pergunta por que a iniciativa de proteção dos notebooks corporativos utiliza três documentos separados em vez de um só. O arquiteto de segurança explica a hierarquia de documentação: um documento expressa a intenção geral da gestão, outro define requisitos técnicos obrigatórios específicos e outro fornece passos ordenados para os técnicos. Qual mapeamento está correto?

A) Padrão = intenção; Política = requisitos obrigatórios; Procedimento = registros de aprovação do conselho

B) Política = requisitos obrigatórios; Padrão = tarefas passo a passo; Diretriz = intenção

C) Política = intenção da gestão; Padrão = requisitos obrigatórios específicos; Procedimento = instruções passo a passo

D) Procedimento = intenção da gestão; Linha de base = requisitos obrigatórios; Diretriz = passos técnicos

QUESTÃO 9 · CENÁRIO DE EXAME

Durante uma auditoria interna, dois documentos que regulam o acesso remoto são examinados. O Documento A afirma que os funcionários 'deveriam' conectar-se pela VPN corporativa ao trabalhar em casa. O Documento B afirma que o acesso remoto 'deve' ocorrer somente pelo cliente VPN fornecido pela empresa, com autenticação multifator habilitada, e violações são tratadas pela equipe de segurança. Como o auditor deve classificar esses documentos?

A) O Documento A é uma diretriz; o Documento B é um padrão

B) Ambos os documentos são padrões; a redação é apenas estilística

C) O Documento A é um padrão; o Documento B é uma diretriz

D) O Documento B é uma regulamentação externa porque usa linguagem obrigatória

QUESTÃO 10 · CENÁRIO DE EXAME

Um CISO recém-contratado em uma indústria de manufatura dedica o primeiro trimestre a construir uma estrutura que define quais papéis podem criar, aprovar e publicar políticas e padrões de segurança; com que frequência esses documentos são revisados; como exceções são concedidas; e como os resultados de conformidade são reportados ao conselho executivo, alinhando a segurança aos objetivos do negócio. O que o CISO estabeleceu?

A) Uma linha de base de plataforma para equipamentos de manufatura

B) Um programa de conformidade regulatória externa

C) Uma política de uso aceitável corporativa consolidada

D) Uma estrutura de governança de segurança

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Um padrão de segurança, porque contém requisitos específicos e obrigatórios que dão suporte à política

Um padrão (standard) é obrigatório e específico — ele traduz uma política ampla em requisitos técnicos exigíveis (neste caso, exatamente os parâmetros de senha) que podem ser auditados. Uma diretriz (guideline) é apenas uma recomendação e não pode ser auditada como obrigatória; uma linha de base descreve a configuração mínima de uma plataforma específica, não regras de senha para toda a organização; um procedimento fornece instruções passo a passo para executar uma tarefa, não requisitos.

Questão 2: Alternativa C — Uma diretriz de boas práticas

Diretrizes (guidelines) são documentos sugeridos, não obrigatórios, que transmitem boas práticas; são a escolha correta quando a organização quer oferecer orientação preservando flexibilidade — exatamente a situação descrita. Um padrão tornaria as configurações obrigatórias e auditáveis, um procedimento apenas descreveria como registrar dispositivos, e uma política é uma declaração de alto nível da gestão sobre intenções, não recomendações técnicas.

Questão 3: Alternativa A — Um procedimento de contenção com ações ordenadas, passo a passo

Um procedimento fornece instruções ordenadas, passo a passo, para executar uma tarefa específica; sua finalidade é garantir consistência na execução — exatamente o problema descrito. Uma política apenas declara intenção e não garantirá execução uniforme; um padrão estabelece requisitos, mas não como executá-los; uma diretriz é conselho opcional e não imporia um processo uniforme.

Questão 4: Alternativa D — Uma política organizacional de alto nível

Uma política é uma declaração ampla e de alto nível da intenção e direção da gestão, que atribui responsabilidades mas omite deliberadamente especificações técnicas; ela é o topo da hierarquia de documentação. Padrões, procedimentos e linhas de base são documentos subordinados: padrões acrescentam requisitos obrigatórios específicos, procedimentos acrescentam os passos de execução e linhas de base definem configurações mínimas de uma plataforma.

Questão 5: Alternativa C — Uma linha de base de configuração mínima para a plataforma

Uma linha de base (baseline) define a configuração mínima de segurança que um sistema ou plataforma deve atender antes da implantação; ficar abaixo dela significa que o sistema não é aceitável para produção. Um procedimento apenas explicaria os passos para configurar um servidor; uma diretriz é opcional e não poderia impor um limite rígido de 'não pode entrar em produção'; e não há autoridade externa envolvida — o requisito se origina dentro da própria organização.

Questão 6: Alternativa B — Uma obrigação de conformidade regulatória imposta externamente

Os requisitos são criados e impostos por uma entidade externa à organização, com consequências financeiras e de negócio em caso de falha — trata-se de conformidade regulatória externa, exemplificada no mundo real pelo PCI DSS para cartões de pagamento, HIPAA para saúde e GDPR para privacidade. A conformidade interna refere-se a regras que a própria organização define; uma linha de base é uma configuração mínima interna; uma diretriz é opcional e não pode impor multas.

Questão 7: Alternativa A — Conformidade interna com requisitos organizacionais autoimpostos

Quando a conformidade é medida contra padrões e políticas que a própria organização criou e aprovou, trata-se de conformidade interna; a autoridade motriz é a própria governança da organização. A conformidade regulatória externa é imposta por entidades externas, como leis, reguladores e mandatos do setor; um adendo de cliente seria contratual; e diretrizes de fornecedores são apenas práticas sugeridas — nenhuma dessas opções corresponde a requisitos elaborados pela própria organização.

Questão 8: Alternativa C — Política = intenção da gestão; Padrão = requisitos obrigatórios específicos; Procedimento = instruções passo a passo

A hierarquia vai do amplo ao específico: uma política transmite a intenção de alto nível aprovada pela gestão; um padrão torna essa intenção exigível por meio de requisitos específicos e obrigatórios; e um procedimento diz aos trabalhadores, passo a passo, como atender a esses requisitos de forma repetível. Cada tipo de documento tem um papel distinto — por isso uma governança madura os mantém separados em vez de fundir tudo em um só documento.

Questão 9: Alternativa A — O Documento A é uma diretriz; o Documento B é um padrão

Documentos obrigatórios usam linguagem diretiva: 'deve' mais consequências definidas para violação marcam o Documento B como um padrão. Documentos que usam 'deveria' ou 'recomendado' transmitem boas práticas sem imposição, o que define uma diretriz — o Documento A. A escolha das palavras reflete diretamente o status de

obrigatório versus sugerido, e nenhuma autoridade externa criou o Documento B, portanto não se trata de uma regulamentação.

Questão 10: Alternativa D — Uma estrutura de governança de segurança

Governança é o sistema geral de direção e supervisão: definir quem tem autoridade para criar e aprovar a documentação de segurança, manter os documentos atualizados, gerenciar exceções, medir a conformidade e reportar aos níveis superiores para que a segurança apoie os objetivos do negócio. As outras opções abordam apenas fatias estreitas da documentação — uma linha de base cobre configurações mínimas, a conformidade externa trata apenas de mandatos externos, e uma única política de uso aceitável não fornece direção e supervisão corporativas gerais.